UNIVERSIDAD POLITÉCNICA DE DURANGO

Ingeniería en Software

INFORME DE REVISIÓN DE CASO DE SOFTWARE

Trazabilidad de normas

Proyecto: +Salud

Sistema de gestión y registro de pacientes con expediente clínico, adherencia a medicación, emergencia por RFID y comunicación médico–paciente

Institución	Universidad Politécnica de Durango
Programa	Ingeniería en Software
Integrantes	Alfredo Valadez González [Nombre del integrante 2]
Normas de referencia	ISO/IEC 27001:2022 · OWASP ASVS 4.0.3 · OWASP MASVS 2.1 · NOM-004-SSA3-2012 · NOM-024-SSA3-2012 · LFPDPPP
Fecha	20 de octubre de 2026
Versión	1.0

Contenido

1. Introducción....3
1.1 Objetivo....3
1.2 Alcance....3
1.3 Descripción del sistema....3
2. Marco normativo de referencia....3
3. Metodología....4
4. Matriz de correspondencia (norma → artefacto)....5
5. Trazabilidad inversa (artefacto → norma)....9
6. Resumen de cobertura....10
7. Justificación de cobertura....10
7.1 Puntos críticos cubiertos....10
7.2 Vacíos identificados y su mitigación....11
7.3 Elementos excluidos del alcance....11
8. Plan de acción y planes de contingencia....12
8.1 Plan de acción....12
8.2 Planes de contingencia (plan B)....14
8.3 Procedimiento ante un incidente de seguridad....15
9. Conclusión....16
Referencias....16

1. Introducción

1.1 Objetivo

Demostrar, mediante una matriz de correspondencia bidireccional, que los requisitos de seguridad y de manejo de información clínica establecidos por las normas de referencia se encuentran implementados en artefactos concretos del sistema **+Salud**, y documentar la evidencia técnica verificable de cada uno.

1.2 Alcance

La revisión cubre el monorepo del proyecto en su estado actual: el backend en Rust/Axum, la base de datos PostgreSQL expuesta mediante PostgREST (20 migraciones), el proxy Caddy, el panel web del médico y administrador, y el cliente móvil Kotlin Multiplatform para Android e iOS. Quedan fuera los procesos organizacionales de la institución que opere el sistema y la infraestructura física del proveedor de alojamiento.

1.3 Descripción del sistema

+Salud permite a los pacientes registrar los medicamentos que toman, llevar su expediente e historial médico, mantener un diario de síntomas y comunicarse con sus médicos de confianza. Incluye un módulo de emergencia por tarjeta RFID, con el que un paramédico consulta un perfil mínimo de supervivencia sin iniciar sesión, y funciones de inteligencia artificial para resumir y traducir conversaciones.

Arquitectura: el cliente se comunica únicamente con Caddy (puerto 8000), que enruta `/auth/*`, `/realtime`, `/tarjetas/*`, `/chat/*`, `/riesgo/*` y `/api/v1/*` al servicio Axum, y el resto de operaciones CRUD/RPC a PostgREST. Axum y PostgREST comparten el secreto JWT, de modo que el token emitido en el inicio de sesión es el mismo que PostgREST valida para aplicar las políticas de seguridad a nivel de fila (RLS) de PostgreSQL.

2. Marco normativo de referencia

Por tratarse de un sistema que procesa datos personales sensibles de salud, se combinaron un marco general de seguridad de la información, estándares técnicos de verificación y la regulación sanitaria y de protección de datos aplicable en México.

Norma / estándar	Propósito en esta revisión	Ámbito
ISO/IEC 27001:2022 — Anexo A	Sistema de gestión de seguridad de la información; se toman los controles organizacionales (A.5) y tecnológicos (A.8) aplicables al software.	Marco principal
OWASP ASVS 4.0.3	Requisitos verificables de seguridad para aplicaciones y API web: autenticación, sesiones, control de acceso, validación, archivos y configuración.	Backend y panel web
OWASP MASVS 2.1	Estándar de verificación de seguridad para aplicaciones móviles: almacenamiento, red, plataforma, código y resiliencia.	App Android / iOS
OWASP API Security Top 10 (2023) y Top 10 (2021)	Riesgos más críticos en API y aplicaciones web; se usan como referencia cruzada.	Backend

Norma / estándar	Propósito en esta revisión	Ámbito
NOM-004-SSA3-2012	Del expediente clínico: contenido mínimo, identificación del paciente y conservación por al menos 5 años.	Expediente y baja
NOM-024-SSA3-2012	Sistemas de información de registro electrónico para la salud: confidencialidad, control de acceso por perfil y bitácoras.	Plataforma completa
LFPDPPP (2025)	Ley Federal de Protección de Datos Personales en Posesión de los Particulares: datos sensibles, minimización, transferencias y derechos ARCO.	Datos personales

3. Metodología

1) Se seleccionaron los controles y requisitos de cada norma aplicables a un sistema de registro electrónico de salud con app móvil y API. 2) Para cada requisito se localizó el artefacto que lo implementa (módulo, migración, archivo o configuración) leyendo el código fuente. 3) Se registró la evidencia técnica con su ruta y, cuando existe, la prueba automatizada que la verifica. 4) Se construyó la trazabilidad inversa agrupando por módulo, para confirmar que ningún artefacto crítico carece de requisito asociado. 5) Se dictaminó el estado de cada requisito con la siguiente escala:

Estado	Criterio
Cumple	El requisito está implementado y existe evidencia en el código, la configuración o las pruebas.
Parcial	Existe una implementación o control compensatorio, pero falta una parte del requisito; se documenta su plan de mitigación.
No aplica	El requisito queda fuera del alcance del caso; se justifica su exclusión.

Las rutas de archivo citadas son relativas a la raíz del repositorio `Salud-frontend-movil`.

4. Matriz de correspondencia (norma → artefacto)

Cada fila vincula un control o requisito normativo con el artefacto del software que lo satisface y con la evidencia técnica que permite verificarlo. El identificador TR-xx se usa como referencia cruzada en la trazabilidad inversa y en la justificación de cobertura.

ID	Norma · cláusula / control	Descripción del requisito	Módulo / artefacto asociado	Evidencia técnica o prueba de cumplimiento	Estado
TR-01	ISO 27001 A.5.15 · A.8.3 ASVS V4.1.1	Control de acceso a la información basado en reglas; cada usuario accede solo a los registros que le pertenecen.	Base de datos (PostgreSQL + PostgREST): expediente, chat, diario, directorio.	Row Level Security habilitada por tabla con 30+ políticas: `pacientes_propio_registro`, `mensajes_visibles_a_participantes`, `entradas_diario_visibles` (`db/migrations/0002`, `0003`, `0006`, `0008`, `0010`). Prueba: pgTAP `db/tests/0003_expediente.sql` (12 aserciones) y `0008_chat.sql` (8).	**Cumple**
TR-02	ISO 27001 A.5.18 NOM-024-SSA3 (acceso por perfil)	Derechos de acceso otorgados y revocados por el titular; separación lectura / escritura.	Módulo Expediente — control de accesos del médico.	Tabla `app.control_accesos_medico` con `nivel_acceso` ∈ {lectura, lectura_escritura}; función `app.tiene_acceso_medico(p_id_paciente, p_requiere_escritura)` usada por las políticas `_lectura` / `_escritura` (`0003_expediente_paciente.sql:126-185`). Solo el paciente edita la tabla (`control_accesos_editable_por_dueno`).	**Cumple**
TR-03	ISO 27001 A.8.2 ASVS V4.1.3	Principio de mínimo privilegio y separación de roles.	Roles Postgres `anon`, `paciente`, `medico`; panel web médico/administrador.	GRANT por rol y por columna (`0009_citas_agenda.sql:135-151`); funciones `SECURITY DEFINER` con `set search_path = app, pg_temp` y `revoke all ... from public` (`0018_cuentas_panel.sql:353`). El panel rechaza cualquier rol distinto de `medico`/`admin` con 403 `ACCESO_DENEGADO` (`backend/src/dashboard/sesion_panel.rs`).	**Cumple**
TR-04	ISO 27001 A.5.17 · A.8.5 ASVS V2.4.1 · V2.4.5	Almacenamiento de contraseñas con función de derivación resistente y secreto adicional (pepper).	Backend Axum — módulo `auth`.	Argon2id v0x13 con salt aleatorio por hash (`OsRng`) y pepper `ARGON2_SECRET_KEY` fuera de la BD (`backend/src/auth/password.rs`). 4 pruebas unitarias: contraseña correcta, incorrecta, pepper distinto y no determinismo.	**Cumple**
TR-05	ASVS V2.1.1 · V2.1.2	Longitud mínima de 8 y máxima de 128 caracteres; misma regla en cliente y servidor.	Backend `auth/handlers.rs`; app `ValidadorLogin`.	`MINIMO_CARACTERES_CONTRASENA = 8`, `MAXIMO = 128` (el tope evita abuso de CPU en Argon2) — `backend/src/auth/handlers.rs:24-33`. Respuesta `ContrasenaNoValida`.	**Cumple**
TR-06	ASVS V2.2.1 · V11.1.4 OWASP API4:2023	Defensa contra fuerza bruta y automatización en endpoints sin sesión.	Backend `limite.rs`; rutas de login, alta, recuperación y emergencia RFID.	Rate limiting por IP real (`SmartIpKeyExtractor` tras Caddy): ráfaga de 10 y luego 1 intento/6 s en acceso (`limite::intentos_de_acceso`); 1/s en `/tarjetas/*`. Responde HTTP 429 (`backend/src/limite.rs`, `auth/mod.rs:34`, `emergencia/mod.rs:18`).	**Cumple**

ID	Norma · cláusula / control	Descripción del requisito	Módulo / artefacto asociado	Evidencia técnica o prueba de cumplimiento	Estado
TR-07	ASVS V3.5.3 · V3.3.1 ISO 27001 A.8.5	Tokens de sesión firmados, con expiración y posibilidad de revocación del lado del servidor.	Backend `auth/jwt.rs`; PostgREST; migración 0016.	JWT con `sub`, `role`, `exp` (12 h) e `iat`; secreto compartido Axum/PostgREST. Revocación: `sesiones_validas_desde` + `PGRST_DB_PRE_REQUEST: app.verificar_sesion` rechaza tokens emitidos antes del cierre o de cuentas bloqueadas (`docker-compose.yml`, `0016_dashboard_medico.sql:17-58`). 5 pruebas unitarias en `jwt.rs`.	**Cumple**
TR-08	ISO 27001 A.5.16 NOM-024-SSA3 (identificación de profesionales)	Gestión del ciclo de vida de identidades; validación del profesional de la salud.	Panel web — administración de cuentas.	Estado `estado_verificacion` PENDIENTE/APROBADO/RECHAZADO de la cédula profesional (`0002_auth.sql`); endpoint `PATCH /admin/cuentas/medicos/:id/verificacion`; contraseñas temporales con vencimiento y cambio obligatorio (`dashboard/contrasena_temporal.rs`).	**Cumple**
TR-09	ISO 27001 A.8.15 NOM-024-SSA3 (bitácora) ASVS V7.2	Registro de eventos de seguridad y de acceso a información clínica.	Tablas de auditoría; endpoint `GET /api/v1/admin/auditoria`.	`app.auditoria_rfid` (cada lectura de tarjeta con resultado e IP), `app.auditoria_reset_cuenta` y `app.auditoria_cuentas` (altas, bloqueos, restablecimientos) con RLS e índices por fecha (`0005`, `0016`, `0018`). Consulta unificada `app.panel_eventos_auditoria()`.	**Cumple**
TR-10	ASVS V7.1.1 · V7.1.2 ISO 27001 A.8.11	No registrar credenciales, tokens ni datos sensibles en los logs.	Backend `routes.rs` (TraceLayer).	El span de trazas registra solo método y ruta, nunca la query: el WebSocket envía el token en `?token=` (`backend/src/routes.rs`). Errores de IA se registran con `tracing` y nunca se exponen al cliente (`docs/errores.md`).	**Cumple**
TR-11	ISO 27001 A.8.16	Actividades de monitoreo y correlación de eventos.	Panel web — middleware `con_id_de_peticion`.	Cabecera `X-Request-ID` validada (≤ 64 caracteres, alfanumérica) que acompaña los logs y regresa en la respuesta (`backend/src/dashboard/mod.rs:78`). Health-check `GET /healthz`.	**Cumple**
TR-12	ASVS V7.4.1 OWASP API3:2023	Mensajes de error genéricos que no revelan existencia de recursos ni detalles internos.	Contrato de errores `docs/errores.md`; `AppError`.	Todo error responde `{"message": "MOTIVO"}`. Se unifican a propósito motivos para evitar enumeración: `TOMA_DESCONOCIDA` (no existe o RLS no la deja ver) y `FRANJA_OCUPADA` (ocupada, bloqueada o inexistente).	**Cumple**
TR-13	ISO 27001 A.8.24 · A.8.20 MASVS-NETWORK-1	Cifrado de la información en tránsito (TLS) en producción.	App Android — `androidApp/build.gradle.kts`; proxy Caddy.	El build release **no compila** si `salud.baseUrl.release` no inicia con `https://` (`build.gradle.kts:113-120`). El tráfico HTTP solo se permite en el source set `src/debug` (`network_security_config.xml`), que no se empaqueta en release.	**Cumple**
TR-14	MASVS-NETWORK-2	Fijación de certificado (certificate pinning) hacia el backend.	App móvil — cliente Ktor.	No implementado. Se depende de la validación estándar de la cadena de confianza del sistema operativo. Ver plan de mitigación (sección 7.2).	**Parcial**
TR-15	MASVS-STORAGE-2 ISO 27001 A.8.12	Evitar fuga de datos sensibles por respaldos, transferencia entre dispositivos o compartición de archivos.	App Android — `AndroidManifest.xml`, `res/xml/`.	`android:allowBackup="false"` y `reglas_extraccion_datos.xml` que excluye root, file, database, sharedpref y external tanto en *cloud-backup* como en *device-transfer*. `FileProvider` limitado a `adjuntos/` (`rutas_adjuntos.xml`).	**Cumple**

ID	Norma · cláusula / control	Descripción del requisito	Módulo / artefacto asociado	Evidencia técnica o prueba de cumplimiento	Estado
TR-16	MASVS-STORAGE-1 ISO 27001 A.8.24	Datos sensibles almacenados en el dispositivo protegidos con cifrado.	App — `data/sesion/AlmacenDeSesion.kt`; base local SQLDelight.	La sesión guarda solo id, rol y token en DataStore (sin datos clínicos, documentado en el código). DataStore y la base local no están cifrados; la exposición se limita a dispositivos con root. Ver sección 7.2.	**Parcial**
TR-17	MASVS-PLATFORM-1 LFPDPPP (minimización)	Solicitar únicamente los permisos estrictamente necesarios y en contexto.	App Android — `AndroidManifest.xml`.	Se retiraron `CAMERA` (el escáner de ML Kit no la requiere), `USE_EXACT_ALARM` y `RECEIVE_BOOT_COMPLETED`. `RECORD_AUDIO` se pide al tocar el micrófono; NFC declarado como `required="false"`.	**Cumple**
TR-18	MASVS-RESILIENCE-3 MASVS-CODE-1	Ofuscación del binario y firma de la aplicación con clave protegida.	App — build release; `keystore.properties`.	R8 con `isMinifyEnabled = true` (APK 3.1 MB vs 21.6 MB debug) y reglas para kotlinx.serialization, Ktor y SQLDelight. Llave de firma fuera de git (`*.jks`, `keystore.properties`) y Play App Signing (`PRODUCTION_CHECKLIST.md`).	**Cumple**
TR-19	ASVS V12.1.1 · V13.1 OWASP API4:2023	Límite de tamaño y validación de archivos subidos; solo participantes autorizados.	Backend `adjuntos/`.	Límite de 10 MB por archivo y `DefaultBodyLimit` (`adjuntos/mod.rs:14,29`); tipos permitidos `FOTO`, `ARCHIVO`, `ESCANEO`; verificación `es_participante` de la conversación antes de guardar.	**Cumple**
TR-20	ASVS V12.5.2 · V14.4.1 OWASP Top 10 A03	Evitar ejecución de contenido activo (XSS) al servir archivos de usuarios.	Backend `adjuntos/handlers.rs`.	Lista `TIPOS_NO_SERVIBLES` (html, xhtml, svg, js, xml): se entregan como binario genérico y nunca se renderizan en el dominio del backend.	**Cumple**
TR-21	ASVS V14.5.3 OWASP Top 10 A05	Política CORS restrictiva para el panel web.	Backend `dashboard/mod.rs:109`; `.env.example`.	Lista blanca `CORS_ORIGENES` con `AllowOrigin::list`; en producción se documenta el dominio exacto del panel y se prohíbe `*`.	**Cumple**
TR-22	ASVS V5.3.4 OWASP Top 10 A03	Consultas parametrizadas para evitar inyección SQL.	Backend (sqlx) y funciones RPC.	Toda consulta en Axum usa `sqlx::query_as` con `.bind(...)` (p. ej. `emergencia/handlers.rs`); PostgREST traduce filtros a SQL parametrizado; errores por `app.lanzar_error(status, motivo)`.	**Cumple**
TR-23	ISO 27001 A.8.9 · A.5.17 ASVS V14.1	Gestión segura de la configuración y de los secretos.	`.env`, `.gitignore`, `scripts/set_secrets.sh`, `docker-compose.yml`.	`.env` excluido de git; secretos (`JWT_SECRET`, `ARGON2_SECRET_KEY`, `AUTHENTICATOR_PASSWORD`) inyectados por variables de entorno y generados con `openssl rand -base64 48`. Firma JWT y hashing nunca en SQL (`0002_auth.sql`). `seed_demo.sh` prohibido en producción.	**Cumple**
TR-24	ISO 27001 A.5.34 LFPDPPP (proporcionalidad) NOM-024-SSA3 (confidencialidad)	Minimización de datos personales expuestos sin sesión.	Módulo Emergencia RFID (`/tarjetas/:id`).	Perfil de supervivencia "deliberadamente pobre": solo nombre, fecha de nacimiento, tipo de sangre, donación, condiciones críticas, medicación de rescate y alergias; nunca CURP, teléfono ni historial (`docs/contratos-datos-backend.md` §5, `emergencia/handlers.rs`). Tarjeta revocada → 403. pgTAP `0005_emergencia.sql`.	**Cumple**
TR-25	ISO 27001 A.8.10 LFPDPPP (derechos ARCO: cancelación) Política Google Play	Eliminación de cuenta y de datos no clínicos a petición del titular.	Función `app.dar_de_baja_paciente`; página `/auth/eliminar-cuenta`.	Se borran correo, contraseña, teléfono, contactos de emergencia, CURP/NSS, accesos de médicos y citas futuras; la tarjeta RFID se revoca (`0012_baja_de_cuentas.sql`). Disponible en la app (Ajustes → Cuenta) y en web.	**Cumple**

ID	Norma · cláusula / control	Descripción del requisito	Módulo / artefacto asociado	Evidencia técnica o prueba de cumplimiento	Estado
TR-26	NOM-004-SSA3-2012 §5.4	Conservación del expediente clínico por un mínimo de 5 años.	Migración 0012; `pg_cron`.	Parámetro `anios_retencion_expediente = 5`; el expediente se conserva tras la baja y se purga automáticamente al vencer (`cron.schedule('purgar-expedientes-vencidos', '30 3 * * *')`).	**Cumple**
TR-27	NOM-004-SSA3-2012 §5.2 · §5.9	Identificación del paciente y contenido mínimo del expediente (alergias, diagnósticos, tratamientos).	Módulos Expediente, Adherencia y Diario.	Tras la baja se conservan nombre, fecha de nacimiento, sexo, alergias, diagnósticos, cirugías, tratamientos, adherencia y comunicación clínica (`0012_baja_de_cuentas.sql`, `0003_expediente_paciente.sql`).	**Cumple**
TR-28	ISO 27001 A.5.14 · A.5.19 LFPDPPP (transferencias)	Control de la transferencia de información a terceros (proveedores de IA).	Backend `ia/` (DeepSeek, Google, Ollama).	Módulo opcional: sin llave responde `IA_NO_CONFIGURADA` (503). Para traducción se prioriza un Ollama propio, con lo que el texto del paciente no sale de la red (`.env.example`, `ia/handlers.rs:133`).	**Cumple**
TR-29	ISO 27001 A.8.6 OWASP API4:2023	Gestión de capacidad y protección ante consumo excesivo de recursos.	Backend `routes.rs`; migración 0020.	`TimeoutLayer` de 60 s por petición, compresión gzip/br, límite de cuerpo en adjuntos e índices de rendimiento (`0020_indices_y_rendimiento.sql`).	**Cumple**
TR-30	ISO 27001 A.8.13	Respaldo periódico de la información.	Infraestructura Docker (`db-data`).	Persistencia en volumen Docker; el repositorio aún no automatiza respaldos cifrados de la base. Ver sección 7.2.	**Parcial**
TR-31	ISO 27001 A.8.29 · A.8.25	Pruebas de seguridad dentro del ciclo de desarrollo.	`db/tests/`, `backend/tests/`, `scripts/`, `shared/src/commonTest`.	81 aserciones pgTAP sobre esquema y políticas RLS (9 módulos); 57 pruebas Rust (unitarias e integración `auth_test.rs`); 560 pruebas del cliente KMP; `verificar_demo.sh` con 122 comprobaciones y `smoke.sh` (11 módulos) contra el stack real.	**Cumple**
TR-32	ISO 27001 A.8.32	Gestión de cambios controlada y reproducible.	`db/migrations/0001…0020`; repositorio git.	Esquema versionado en 20 migraciones aplicadas en orden por `scripts/migrate.sh` en el contenedor `migrate`; historial en git del monorepo.	**Cumple**

5. Trazabilidad inversa (artefacto → norma)

Para cerrar la relación bidireccional, la siguiente tabla parte de cada módulo del sistema y enumera los requisitos de la matriz que lo cubren. Todos los módulos funcionales tienen al menos un control normativo asociado.

Módulo / artefacto	Ubicación en el repositorio	Requisitos (ID)	Normas relacionadas
Autenticación (paciente y profesional)	`backend/src/auth/`, `0002_auth.sql`	TR-04, TR-05, TR-06, TR-07, TR-23	ISO A.5.17, A.8.5 · ASVS V2, V3
Expediente clínico	`0003_expediente_paciente.sql`	TR-01, TR-02, TR-27	ISO A.5.15, A.5.18 · NOM-004 · NOM-024
Adherencia a medicación	`0004_adherencia.sql`, `0011`	TR-01, TR-12, TR-27	ISO A.5.15 · ASVS V7.4 · NOM-004
Emergencia por tarjeta RFID	`backend/src/emergencia/`, `0005_emergencia.sql`	TR-06, TR-09, TR-22, TR-24	ISO A.5.34, A.8.15 · ASVS V2.2, V5.3 · LFPDPPP
Directorio y cartera de pacientes	`0006`, `0007`	TR-01, TR-03	ISO A.5.15, A.8.2 · ASVS V4
Chat y adjuntos	`0008_chat.sql`, `0013`, `backend/src/adjuntos/`	TR-01, TR-19, TR-20	ISO A.5.15 · ASVS V12, V14.4
Citas y agenda	`0009_citas_agenda.sql`, `0014`	TR-03, TR-12	ISO A.8.2 · ASVS V4.1, V7.4
Diario y análisis de riesgo	`0010_diario.sql`, `0019`, `backend/src/riesgo/`	TR-01, TR-27	ISO A.5.15 · NOM-004
Inteligencia artificial (resumen y traducción)	`backend/src/ia/`	TR-10, TR-28	ISO A.5.14, A.5.19, A.8.11 · LFPDPPP
Panel web médico / administrador	`backend/src/dashboard/`, `0016`–`0018`	TR-03, TR-07, TR-08, TR-09, TR-11, TR-21	ISO A.5.16, A.8.15, A.8.16 · ASVS V14.5 · NOM-024
Baja de cuentas y retención	`0012_baja_de_cuentas.sql`	TR-25, TR-26, TR-27	ISO A.8.10 · LFPDPPP · NOM-004 §5.4
App móvil Android / iOS (KMP)	`frontend/androidApp`, `frontend/shared`	TR-13, TR-14, TR-15, TR-16, TR-17, TR-18	MASVS NETWORK, STORAGE, PLATFORM, RESILIENCE, CODE
Infraestructura (Docker, Caddy, PostgREST)	`docker-compose.yml`, `deploy/caddy/`	TR-07, TR-23, TR-29, TR-30, TR-32	ISO A.8.6, A.8.9, A.8.13, A.8.32
Pruebas automatizadas	`db/tests/`, `backend/tests/`, `scripts/`	TR-31	ISO A.8.25, A.8.29

6. Resumen de cobertura

Familia normativa	Requisitos	Cumple	Parcial	% Cumple
ISO/IEC 27001:2022	15	14	1	93 %
OWASP ASVS / API Top 10	9	9	0	100 %
OWASP MASVS	6	4	2	67 %
NOM-004-SSA3-2012	2	2	0	100 %
Total	**32**	**29**	**3**	**90.6 %**

De los 32 requisitos trazados, 29 se cumplen con evidencia verificable y 3 se cumplen de forma parcial con controles compensatorios. No hay requisitos aplicables sin atender. Los controles de NOM-024-SSA3-2012 y la LFPDPPP se contabilizan dentro de la familia de su control principal, ya que en la matriz aparecen como referencia cruzada.

7. Justificación de cobertura

7.1 Puntos críticos cubiertos

Los puntos críticos para un sistema de registro electrónico de salud son la confidencialidad del expediente, la autenticidad de quien accede, la trazabilidad de los accesos y el ciclo de vida legal de los datos. Todos quedaron cubiertos:

- **Confidencialidad del expediente:** el control de acceso se aplica en la propia base de datos mediante RLS (TR-01, TR-02), de modo que ni un error en el backend ni una llamada directa a PostgREST permiten leer registros ajenos; el panel y los roles refuerzan el mínimo privilegio (TR-03).
- **Autenticación y sesiones:** Argon2id con pepper, política de longitud, limitación de intentos y JWT con expiración y revocación en servidor (TR-04 a TR-07), más verificación de la cédula profesional del médico (TR-08).
- **Trazabilidad:** bitácoras de lecturas RFID y de acciones administrativas, correlación por X-Request-ID y logs sin secretos (TR-09 a TR-11), como pide NOM-024-SSA3.
- **Superficie sin sesión:** el único endpoint público (emergencia RFID) entrega un perfil mínimo, está limitado por IP y queda auditado (TR-06, TR-09, TR-24).
- **Ciclo de vida legal:** la baja de cuenta elimina lo no clínico y conserva el expediente 5 años con purga automática, conciliando la LFPDPPP con la NOM-004 (TR-25 a TR-27).
- **Aplicación móvil:** TLS obligatorio en release, exclusión de respaldos, permisos mínimos y binario ofuscado y firmado (TR-13, TR-15, TR-17, TR-18).

7.2 Vacíos identificados y su mitigación

Tres requisitos se dictaminaron como parciales. En cada caso existe un control compensatorio vigente y una acción concreta para cerrarlo:

ID	Vacío	Control compensatorio vigente	Acción de cierre
TR-14	Sin fijación de certificado.	TLS obligatorio en release (TR-13) y backend solo expuesto por Caddy.	Agregar `CertificatePinner` en el motor OkHttp de Ktor con pin de la llave pública y un pin de respaldo.
TR-16	Token y base local sin cifrar.	Sin datos clínicos en DataStore; `allowBackup=false` y exclusión total de respaldos (TR-15); revocación de sesiones en servidor (TR-07).	Mover el token a Android Keystore / iOS Keychain y cifrar la base local con SQLCipher.
TR-30	Respaldos no automatizados en el repositorio.	Volumen persistente y migraciones reproducibles (TR-32).	Tarea `pg_dump` diaria cifrada fuera del servidor y prueba trimestral de restauración.

7.3 Elementos excluidos del alcance

Los siguientes controles no se trazaron porque no corresponden a un artefacto de software o quedan fuera del alcance del caso:

Control / requisito	Motivo de la exclusión	Estado
ISO 27001 A.6 (controles de personas)	Selección, capacitación y acuerdos de confidencialidad del personal son responsabilidad de la institución operadora, no del artefacto de software.	**No aplica**
ISO 27001 A.7 (controles físicos)	El sistema se despliega en un servidor virtual de un proveedor; la seguridad física del centro de datos la asume el proveedor (A.5.23).	**No aplica**
ISO 27001 A.5.24 – A.5.28 (gestión de incidentes)	Procesos organizacionales. El software aporta la materia prima (bitácoras TR-09, X-Request-ID TR-11) para que la organización los opere.	**No aplica**
MASVS-RESILIENCE-1/2 (detección de root, anti-manipulación)	El modelo de amenaza no incluye un atacante con control del dispositivo del propio paciente; la información sensible reside en el servidor tras RLS.	**No aplica**
MASVS-AUTH-3 / ASVS V2.8 (segundo factor)	Fuera del alcance del prototipo académico; se registra como mejora para cuentas de administrador del panel.	**No aplica**
NOM-024-SSA3 — interoperabilidad (HL7 / CDA, catálogos CIE-10) y firma electrónica avanzada	El caso no intercambia expedientes con otras instituciones ni emite documentos con valor legal; se excluye de este alcance.	**No aplica**

8. Plan de acción y planes de contingencia

Esta sección complementa la justificación de cobertura con lo que debe hacerse para cerrar los vacíos y preparar la puesta en producción, y con el plan alterno (plan B) previsto para cada punto crítico si el control principal falla.

8.1 Plan de acción

Acciones ordenadas por prioridad. Las de prioridad alta son condición para operar con pacientes reales.

ID	Acción	Requisito	Prioridad	Plazo	Responsable	Criterio de verificación
A-01	Fijar el certificado del backend en el cliente Ktor (`CertificatePinner` de OkHttp en Android, delegado de `URLSession` en iOS) con un pin principal y uno de respaldo.	TR-13, TR-14	**Alta**	Antes de producción	Equipo móvil	Una petición contra un certificado distinto falla; prueba instrumentada con un proxy MITM.
A-02	Mover el token de sesión a Android Keystore / iOS Keychain y cifrar la base local con SQLCipher; la llave nunca sale del almacén seguro.	TR-16	**Alta**	Antes de producción	Equipo móvil	El archivo de DataStore y la base local no contienen texto legible en un dispositivo con root.
A-03	Respaldo diario con `pg_dump` cifrado (GPG/age) copiado fuera del servidor, con retención de 30 días y prueba de restauración trimestral.	TR-30	**Alta**	Antes de producción	Administrador del sistema	Bitácora de respaldos y acta de la última restauración exitosa.
A-04	Rotar todos los secretos del `.env` (`POSTGRES_PASSWORD`, `JWT_SECRET`, `AUTHENTICATOR_PASSWORD`, `ARGON2_SECRET_KEY`) con `openssl rand -base64 48` y fijar `RUST_LOG=info`.	TR-23	**Alta**	Al desplegar	Administrador del sistema	Ningún valor `change-me` en el servidor; logs sin nivel debug.
A-05	Publicar el backend con dominio propio y HTTPS; `CORS_ORIGENES` solo con el dominio del panel (sin `red-local` ni `*`).	TR-13, TR-21	**Alta**	Al desplegar	Administrador del sistema	El panel funciona desde su dominio y una petición desde otro origen es rechazada.
A-06	Eliminar la cuenta demo `admin@salud.local`, no ejecutar `seed_demo.sh` y crear el primer administrador con `backend crear-admin`.	TR-03, TR-08	**Alta**	Al desplegar	Administrador del sistema	Consulta a `app.administradores` sin cuentas demo.
A-07	Publicar la política de privacidad con lo que se borra y lo que se conserva 5 años (NOM-004), y la URL `/auth/eliminar-cuenta` en Play Console.	TR-25, TR-26	**Alta**	Antes de publicar en Play	Responsable del producto	URL pública accesible y formulario de Seguridad de los datos aprobado.
A-08	Segundo factor (TOTP) para administradores del panel web.	Exclusión 7.3	**Media**	Siguiente versión	Equipo backend	El inicio de sesión de administrador exige el código.

ID	Acción	Requisito	Prioridad	Plazo	Responsable	Criterio de verificación
A-09	Política `restart: unless-stopped` en los servicios de `docker-compose.yml` y monitoreo externo de `GET /healthz` con alerta.	TR-29	**Media**	Al desplegar	Administrador del sistema	Al detener un contenedor se reinicia solo y llega la alerta.
A-10	Receptor de `BOOT_COMPLETED` que reprograme los recordatorios tras reiniciar el teléfono.	TR-17	**Media**	Siguiente versión	Equipo móvil	Prueba: reiniciar el dispositivo y verificar que la siguiente toma suena.
A-11	Revisión mensual de la bitácora de auditoría (lecturas RFID, restablecimientos y bloqueos) en el panel.	TR-09	**Baja**	Mensual	Administrador del sistema	Minuta de revisión firmada.

8.2 Planes de contingencia (plan B)

Para cada escenario se indica el control principal (plan A), la respuesta alterna (plan B) y si esta ya existe en el código o debe implementarse.

Escenario de riesgo	Plan A (control principal)	Plan B (contingencia)	Estado del plan B
Proveedor de IA caído o sin cuota	Traducción con Ollama propio (el texto no sale de la red).	Cadena de respaldo: Google Translation → DeepSeek. Si ninguno responde, `IA_NO_DISPONIBLE` y el médico ve el mensaje original; el resto del sistema sigue funcionando.	**Implementado**
El paciente se queda sin internet	Consulta en línea contra el backend.	`RespaldoSinConexion` guarda las respuestas y las muestra sin conexión; el cliente genera `SIN_CONEXION` localmente en vez de fallar.	**Implementado**
El servidor de desarrollo cambia de IP	URL fija configurada en el build.	`VigiaDeServidor` busca el backend en la subred y redirige las peticiones siguientes.	**Implementado**
El paciente niega la alarma exacta	Alarma exacta para cada toma.	Se degrada a alarma inexacta (el aviso llega, con menor precisión) y la pantalla de inicio vuelve a pedir el permiso.	**Implementado**
El teléfono se reinicia	Recordatorios programados en el sistema.	Las tomas del día se reprograman al abrir la pantalla de inicio (definitivo: acción A-10).	**Parcialmente**
Tarjeta RFID extraviada o robada	La tarjeta solo expone un perfil mínimo.	Se revoca la tarjeta → `TARJETA_REVOCADA` (403); la bitácora `auditoria_rfid` muestra quién la leyó y desde qué IP.	**Implementado**
Dispositivo sin NFC	Lectura de tarjeta por NFC.	NFC es opcional: el resto de la app funciona. Propuesto: código QR impreso en la tarjeta como lector alterno.	**Por implementar**
Robo del teléfono o del token	Token con expiración de 12 h.	Desde el panel se restablece la cuenta: `sesiones_validas_desde` invalida todos los tokens previos de inmediato.	**Implementado**
Filtración de la base de datos	Hashes Argon2id con pepper fuera de la BD.	Rotar `JWT_SECRET` (cierra todas las sesiones) y `ARGON2_SECRET_KEY` con restablecimiento obligatorio de contraseñas; aviso a titulares según la LFPDPPP.	**Por implementar**
Pérdida o corrupción de la base de datos	Volumen persistente `db-data`.	Recrear el esquema con las migraciones 0001–0020 y restaurar el último respaldo cifrado (acción A-03).	**Por implementar**
Caída del backend	Healthcheck de Docker.	Reinicio automático y alerta (A-09); mientras tanto la app muestra los datos guardados sin conexión.	**Parcialmente**
Ataque de fuerza bruta o abuso	Límite de intentos por IP (429).	Bloquear la IP en Caddy o en el firewall y bloquear la cuenta afectada (`CUENTA_BLOQUEADA`) desde el panel.	**Implementado**
Médico suplantado o no verificado	Cédula en estado PENDIENTE hasta aprobarla.	El administrador rechaza la cédula, bloquea la cuenta y cierra sus sesiones; queda en `auditoria_cuentas`.	**Implementado**
Se pierde la llave de firma de la app	Llave guardada fuera del equipo.	Play App Signing: Google reemplaza la clave de subida sin perder las actualizaciones.	**Implementado**

Escenario de riesgo	Plan A (control principal)	Plan B (contingencia)	Estado del plan B
El certificado fijado cambia (tras A-01)	Pin principal.	Pin de respaldo de la siguiente llave y actualización forzada de la app antes de rotar el certificado.	**Por implementar**
El paciente ya no tiene la app y quiere su baja	Baja desde Ajustes → Cuenta.	Página web `/auth/eliminar-cuenta` con el mismo efecto.	**Implementado**

8.3 Procedimiento ante un incidente de seguridad

- **Detectar:** alerta del monitoreo de `/healthz`, picos de respuestas 429 o lecturas RFID anómalas en la bitácora; correlacionar con `X-Request-ID`.
- **Contener:** bloquear la IP en Caddy/firewall, bloquear la cuenta o revocar la tarjeta afectada y cerrar sus sesiones desde el panel.
- **Erradicar:** rotar los secretos comprometidos (`JWT_SECRET`, `ARGON2_SECRET_KEY`, contraseñas de base de datos) y corregir la causa en el código.
- **Recuperar:** restaurar desde el último respaldo cifrado si hubo pérdida o alteración de datos y verificar con `scripts/smoke.sh` y `scripts/verificar_demo.sh`.
- **Notificar y aprender:** informar a los titulares afectados conforme a la LFPDPPP, documentar el incidente y agregar la prueba que lo habría detectado.

9. Conclusión

La revisión confirma una relación bidireccional completa entre las normas de referencia y los artefactos de +Salud: cada requisito aplicable apunta a un módulo y a evidencia verificable, y cada módulo funcional se respalda en al menos un requisito. El 90.6 % de los requisitos se cumple plenamente; los tres restantes cuentan con controles compensatorios y un plan de cierre definido. Atender esos tres puntos —fijación de certificado, cifrado del almacenamiento local y respaldos automatizados— junto con las demás acciones de prioridad alta del plan de acción (sección 8.1) es la condición recomendada antes de operar el sistema con pacientes reales. Los planes de contingencia de la sección 8.2 aseguran que, ante la falla de un control principal, el sistema degrade de forma controlada en lugar de exponer información clínica.

Referencias

ISO/IEC 27001:2022. Information security, cybersecurity and privacy protection — Information security management systems — Requirements. ISO.

OWASP Foundation (2021). Application Security Verification Standard 4.0.3.

OWASP Foundation (2024). Mobile Application Security Verification Standard (MASVS) 2.1.

OWASP Foundation (2023). OWASP API Security Top 10.

Secretaría de Salud (2012). NOM-004-SSA3-2012, Del expediente clínico. Diario Oficial de la Federación.

Secretaría de Salud (2012). NOM-024-SSA3-2012, Sistemas de información de registro electrónico para la salud. Diario Oficial de la Federación.

Congreso de la Unión (2025). Ley Federal de Protección de Datos Personales en Posesión de los Particulares. Diario Oficial de la Federación.